

איך לקרוא את הפרק הזה

בפרק הקודם הקשחנו נתב אחד ונתנו לו סיסמה מקומית. אבל מה עושים כשיש עשרות נתבים ומתגים ועשרות אנשים שצריכים גישה? כאן נכנס מודל ה-AAA הפרק כתוב לקריאה רציפה: נתחיל מהבעיה שהמודל בא לפתור, נבין את שלוש ה-A במילים פשוטות, ורק אז נגיע לפרוטוקולים ולפקודות. כל מונח מוסבר בפעם הראשונה שהוא מופיע.

3.1 הבעיה: איך מנהלים גישה בעשרות מכשירים?

נזכיר מהפרק הקודם: הגדרנו על הנתב **משתמש מקומי** (local user) – שם וסיסמה ששמורים בתוך הנתב עצמו. זה עובד מצוין לנתב אחד. אבל דמיינו רשת של בית ספר או חברה עם 50 נתבים ומתגים, ו-10 אנשי צוות שצריכים לנהל אותם. אם כל מכשיר מחזיק את רשימת המשתמשים שלו, נוצרות שתי בעיות כואבות: ראשית, כדי להוסיף עובד חדש צריך להיכנס ידנית ל-50 מכשירים; שנית – זהו החמור – כשעובד בזז, צריך לזכור למחוק אותו מכל 50 המכשירים, ואם שוכחים אפילו אחד, נשאר דלת פתוחה.

הפתרון: **ניהול מרכזי**. במקום שכל מכשיר יחזיק רשימת משתמשים משלו, יש דחא סוקמ – שרת מרכזי – שכל המכשירים שואלים אותו "האם להכניס את המשתמש הזה, ומה מותר לו?". הוספה או מחיקה של עובד נעשית פעם אחת, במקום אחד, ומשפיעה על כל הרשת. זו בדיוק המסגרת שנקראת AAA.

3.2 שלוש ה-A: מה קורה כשמתחברים

כשאתם נכנסים לחשבון כלשהו – מייל, בנק, נתב – קורים שלושה דברים נפרדים שאנשים נוטים לבלבל ביניהם. מודל AAA (שלושה ראשי תיבות באנגלית) בדיוק מסדר אותם:

- **אימות** (Authentication) – עונה על השאלה "התא ימ". זהו שלב הוכחת הזהות, למשל בעזרת שם משתמש וסיסמה.
- **הרשאה** (Authorization) – עונה על השאלה "תושעל קל רתומ המ". אחרי שידוע מי אתה, ההרשאה קובעת מה מותר – האם רק לצפות, או גם לשנות הכול? לאילו מכשירים יש לך גישה?
- **רישום** (Accounting) – עונה על השאלה "יתמו, תישע המ". זהו תיעוד של פעולות המשתמש: מתי נכנס, אילו פקודות הקליד, מתי יצא.

המשל שעוזר לזכור: שדה התעופה

דמיינו כניסה לטיסה. **אימות** = בדיקת הדרכון בכניסה – מוודאים שאתם מי שאתם טוענים שאתם. **הרשאה** = כרטיס הטיסה – גם אחרי שידוע מי אתם, מותר לכם לעלות רק לטיסה שלכם, לא לכל מטוס בשדה. **רישום** = רשימת הנוסעים שהמדינה שומרת – מי עלה, מתי, עם כמה מזוודות. שימו לב לסדר ההגיוי: אי אפשר לתת הרשאה בלי לדעת קודם מי האדם (אימות), ואי אפשר לרשום פעולות של מישהו אלמוני.

גורמי אימות – שלוש דרכים להוכיח מי אתה

איך מוכיחים זהות? יש שלושה "גורמים" (factors), ולכל אחד יתרון וחיסרון:

- **משהו שאתה יודע** – סיסמה, קוד PIN קל לשימוש, אבל אפשר לגנוב או לנחש.
- **משהו שיש לך** – הטלפון (שמקבל קוד חד-פעמי), כרטיס חכם, טוקן. קשה יותר לגנוב מרחוק.
- **משהו שאתה** – ביומטריה: טביעת אצבע, זיהוי פנים. קשה מאוד לזייף.

כשמשלבים סינוש סיגוסמ סימרוג ינש מקבלים **אימות רב-שלבי** (MFA), או במקרה של שניים בדיוק – 2FA. זו הגנה חזקה מאוד: גם אם תוקף גנב את הסיסמה שלכם (משהו שאתם יודעים), עדיין חסר לו הטלפון (משהו שיש לכם). שימו לב: שתי סיסמאות אינן MFA – חייבים גורמים משני סוגים שונים.

3.3 שני מצבים: AAA מקומי מול מבוסס-שרת

יש שתי דרכים להפעיל AAA ב-AAA מקומי (Local) המכשיר מאמת מול רשימת משתמשים ששמורה בו עצמו - פשוט, מתאים לרשת קטנה, וגם משמש כ"גיבוי" למקרה שהשרת המרכזי לא זמין. ב-AAA מבוסס-שרת (Server-based) המכשיר פונה ל**יזכרם תרש** ושואל אותו - זו הגישה הנכונה לארגון, כי היא נותנת ניהול אחיד ורישום מרוכז.

כדי לדבר על זה נכון צריך שני מושגים: המכשיר שפונה לשרת (הנתב או המתג) נקרא NAS (Network Access Server) או פשוט "לקוח ה-AAA" והחיבור בין הנתב לשרת מאובטח בעזרת **מפתח משותף** (shared key / secret - סוד שמוגדר **תרשב סגו בתנב סג**, ומשמש להצפין את התקשורת ביניהם ולהוכיח לשרת שהנתב הוא לקוח מורשה שלו.

בלבול נפוץ: המפתח אינו הסיסמה של המשתמש!

המפתח המשותף (key) הוא סוד בין **תרשל בתנה**. הסיסמאות של המשתמשים שמורות בשרת. אלה שני דברים שונים לגמרי: המפתח מאמת את הציווד, הסיסמה מאמתת את האדם. בתכנית הלימודים הביטוי "מפתחות מוצפנים" מתייחס למפתח המשותף הזה.

מהעולם האמיתי: מנהל הרשת שפוטר ביום שלישי

בחברת שירותי אינטרנט פיטרו מנהל רשת. המנכ"ל ביקש מה-IT לובטל לו את הגישה, וה-IT מחק את חשבון ה-Windows שלו. אבל ב-40 הנתבים והמתגים היו חשבונות **סיימוקם** שהמנהל עצמו יצר. שלושה ימים אחר כך, ב-2 בלילה, כל הנתבים "איבדו" את ההגדרות שלהם - ואף אחד לא ידע מי עשה זאת, כי לא היה רישום (Accounting) וכל החשבונות נראו כמו "admin עם AAA מבוסס-שרת, לחיצה אחת הייתה מנתקת אותו מכל הציווד, והרישום היה מראה שם מלא, שעה ופקודה. זה בדיוק ה"למה" של הפרק.

RADIUS 3.4 מול TACACS+ - שני הפרוטוקולים

כשהנתב פונה לשרת המרכזי, הוא מדבר איתו באחד משני פרוטוקולים (שפות). שניהם עושים AAA, אבל יש ביניהם הבדלים חשובים שנשאלים כמעט תמיד בבגרות. נכיר כל אחד, ואז נשווה.

RADIUS הוא תקן פתוח (לא שייך לחברה מסוימת). הוא רץ על פרוטוקול התעבורה UDP (פרוטוקול מהיר וחסר-חיבור), ומצפין המסירה הדש תא קר בבקשה - שאר הפרטים (כולל שם המשתמש) עוברים גלויים. RADIUS גם **בלשמ** את האיומות וההרשאה יחד: כשהשרת מאשר את המשתמש, התשובה כוללת כבר גם את ההרשאות. השימוש האופייני שלו: **גישת משתמשים לרשת** - למשל אימות ל-Wi-Fi ארגוני (802.1X) או ל-VPN מרחוק.

TACACS+ הוא פרוטוקול של חברת סיסקו. הוא רץ על TCP (פרוטוקול אמין שמנהל "שיחה"), פורט 49, ומצפין את **לכ** גוף החבילה - לא רק הסיסמה. הוא גם **דירפמ** בין שלושת השירותים, כך שאפשר, למשל, לאמת מול מקור אחד ולאשר כל פקודה בנפרד מול השרת. השימוש האופייני שלו: **ניהול ציווד רשת** - מנהלים שמתחברים לנתבים ולמתגים, עם אפשרות לאשר כל פקודה שהם מקלידים.

	RADIUS	+TACACS
מי פיתח	תקן פתוח (IETF)	סיסקו
תעבורה	UDP (1812/1813)	TCP (פורט 49)
הצפנה	רק שדה הסיסמה	כל גוף החבילה
הפרדת השירותים	אימות והרשאה משולבים	שלושתם נפרדים
אישור לכל פקודה	לא נתמך	נתמך
שימוש אופייני	גישת משתמשים (Wi-Fi/VPN)	ניהול ציווד

למה RADIUS על UDP אם TCP אמין יותר?

שאלה טובה שתלמידים שואלים. RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים בו-זמנית; UDP קל ומהיר, והלקוח פשוט שולח שוב אם לא קיבל תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית (שאלה-תשובה-שאלה) ורוצה לדעת מיד אם השרת נפל. שניהם עובדים מצוין היום; ההבדל המעשי החשוב הוא ההצפנה המלאה והפרדת השירותים של TACACS+.

3.5 השרתים בפועל: ACS ו-ISE

מי מריץ את שירות ה-AAA? אצל סיסקו, השרת ההיסטורי נקרא ACS (Access Control Server), והיורש המודרני שלו נקרא ISE (Identity Services Engine) - שרת מדיניות שעושה AAA, מנהל 802.1X, ואפילו

בודק את מצב המכשירים שמתחברים. יש גם חלופות שאינן של סיסקו: FreeRADIUS (קוד פתוח) ו-Windows NPS (שרת RADIUS שמובנה ב-Windows Server). השרת יכול לאמת מול מאגר המשתמשים הקיים של הארגון (Active Directory), כך שהמורים משתמשים באותו שם וסיסמה בכל מקום.

3.6 הגדרה בפועל - שלב אחר שלב

עכשיו שהבנו את הרעיון, נראה איך מגדירים. הצעד הראשון תמיד: להפעיל את מנגנון ה-AAA בקודה aaa new-model. מרגע זה, כל קווי הגישה מתחילים להשתמש ב-AAA במקום בשיטה הישנה.

```
R1(config)# username admin secret P@ss ! קודם כול! גיבוי, קודם כול!  
R1(config)# aaa new-model AAA את מסגרת ה-  
R1(config)# tacacs-server host 10.0.0.5 key Key123 +TACACS והמפתח המשותף  
R1(config)# aaa authentication login default group tacacs+ local
```

השורה האחרונה היא "רשימת שיטות" (method list): היא אומרת "כדי לאמת התחברות, נסה קודם את שרת ה-TACACS+; ואם הוא איננו זמין - השתמש במשתמש המקומי". הגיבוי המקומי (local) קריטי: בלעדיו, אם השרת נופל, אף אחד לא יוכל להיכנס.

הטעות המסוכנת ביותר בפרק - היזהרו!

הפקודה aaa new-model משנה מיד את התנהגות כל הקווים. אם תקלידו אותה ילד להגדיר קודם משתמש מקומי ובלי גיבוי local ברשימת השיטות, ואז תתנתקו - **תינעלו מחוץ לנתב**. כלל ברזל: קודם הגדירו username, אחר כך aaa new-model, תמיד סיימו את רשימת השיטות ב-local, והשאירו חלון חיבור פתוח עד שווידאתם בחלון שני שהכול עובד.

נקודה חשובה שנשאלת בבגרות: מעבר לשיטה הבאה ברשימה קורה קר כאשר השיטה הקודמת אינה זמינה (השרת לא עונה). אם השרת עונה "סיסמה שגויה" - המשתמש נדחה, ואין מעבר לשיטה הבאה. כלומר local הוא גיבוי לתקלת-שרת, לא "ניסיון שני" אחרי סיסמה שגויה.

הגדרת שרת RADIUS דומה מאוד, רק עם מילת המפתח radius:

```
R1(config)# radius-server host 10.0.0.6 key R@diusK3y  
R1(config)# aaa authentication login default group radius local
```

הרשאה ורישום

עד כה עסקנו באימות (ה-A הראשון). מוסיפים את שני האחרים בשתי שורות דומות. **הרשאה** (Authorization) קובעת מה מותר למשתמש לעשות אחרי שנכנס - למשל, האם הוא מקבל גישה מנהל (רמה 15) ישירות:

```
R1(config)# aaa authorization exec default group tacacs+ local
```

רישום (Accounting) מתעד את הפעולות. למשל, לתעד כל פקודה ברמה 15 (מנהל) - כדי שתמיד נדע "מי הקליד reload?":

```
R1(config)# aaa accounting commands 15 default start-stop group tacacs+
```

802.1X AAA - שמגן על שקע ברשת

RADIUS משמש גם לדבר חשוב נוסף: לאמת רישום לפני שהוא בכלל מקבל גישה לרשת. התקן שעושה זאת נקרא 802.1X, ויש בו שלושה תפקידים: ה-Supplicant (המחשב או הטלפון שרוצה להתחבר), ה-Authenticator (המתג או נקודת הגישה, שטרופה תא מסוים עד שהאימות מצליח), וה-**שרת האימות** (RADIUS). בקצרה: אי אפשר סתם לחבר מחשב לשקע ולקבל גישה - המתג חוסם אותך עד שאתה מאמת את עצמך מול השרת. זהו הבסיס ל-Wi-Fi ארגוני (WPA2-Enterprise) ולבקרת גישה לרשת (NAC), שנרחיב עליהם בפרק 6.

מהעולם האמיתי: למה ה-Wi-Fi באוניברסיטה שואל שם משתמש

ברשת eduroam (שפועלת באוניברסיטאות בעולם, כולל בישראל) סטודנט מחיפה יכול להתחבר ל-Wi-Fi באוניברסיטה בברלין עם החשבון של הטכניון. איך? המחשב שולח שם משתמש לנקודת הגישה (Authenti-

cator), היא מעבירה את הבקשה לשרת RADIUS בברלין, שרואה את הסימט "@technion.ac.il" ומעביר את השאלה לשרת RADIUS בטכניון, שמאמת ומחזיר "אשר". אף שרת לא צריך להכיר את כל המשתמשים בעולם - רק לדעת למי להעביר. זו בדיוק הסיבה ש-RADIUS הוא "פרוטוקול גישה המשתמשים", בעוד TACACS+ נשאר לניהול הציוד.

3.8 בדיקה ופתרון תקלות

אחרי שמגדירים, איך יודעים שהכול עובד - ואיך מאבחנים כשלא? הנה הכלים המרכזיים ותקלות נפוצות:

```
R1# show aaa sessions AAA מי מחובר כרגע דרך !
R1# test aaa group tacacs+ admin P@ss legacy ! בודק אימות בלי להתחבר בפועל
R1# debug aaa authentication ! מעקב חי אחר תהליך האימות
```

- **הנתב "נתקע" כמה שניות ואז מקבל את המשתמש המקומי:** סימן שהשרת אינו נגיש (בדקו כתובת, ACL, ושהשירות פועל). הגיבוי ל-local עבד - זה תקין, אבל צריך לתקן את הקשר לשרת.
- **"אימות נכשל" מיד, גם עם סיסמה נכונה:** לרוב המפתח המשותף (key) אינו זהה בין הנתב לשרת, או שהשרת לא מכיר את כתובת הנתב כלקוח מורשה.
- **המשתמש נכנס אך לא מקבל הרשאת מנהל:** חסרה שורת ה-aaa authorization exec, או שהשרת לא מחזיר את רמת ההרשאה.

3.9 תרגילים - עם פתרונות

תרגיל 1 - איזה A?

לכל משפט, ציינו אם מדובר באימות, הרשאה או רישום: (א) "המשתמש dana ניסתה להקליד configure terminal ונדחתה". (ב) "החשבון של yossi נעול אחרי 3 ניסיונות כושלים". (ג) "בדוח החודשי: 4,200 חיבורי VPN, ממוצע 38 דקות".

(א) הרשאה (נבדק מה מותר לה לעשות). (ב) אימות (הוכחת זהות בכניסה). (ג) רישום (תיעוד פעולות).

תרגיל 2 - מה יקרה?

נתב מוגדר: aaa authentication login default group tacacs+ local (א) שרת ה-TACACS+ עונה "סיסמה שגויה". (ב) שרת ה-TACACS+ לא עונה כלל, ויש משתמש מקומי. מה קורה בכל מקרה?

(א) המשתמש נדחה - אין מעבר ל-local אחרי דחייה מפורשת. (ב) אחרי timeout הנתב עובר ל-local ומאמת מולו - כי השרת "לא זמין".

תרגיל 3 - בחירת פרוטוקול

לכל תרחיש בחרו RADIUS או TACACS+ ונמקו: (א) אימות 2,000 תלמידים ל-Wi-Fi של בית הספר. (ב) 5 מנהלי רשת שרוצים שמתמחה יוכל להקליד רק פקודות show.

(א) RADIUS - גישה משתמשים לרשת. (802.1X) (ב) TACACS+ - הוא היחיד שתומך באישור נפרד לכל פקודה.

תרגיל 4 - תקלה

מנהל הקליד aaa new-model ואז aaa authentication login default group tacacs+ local (בלי local). השרת נפל, והמנהל התנתק. מה קרה, ואיך מונעים זאת?

הוא ננעל מחוץ לנתב - אין שיטת גיבוי כשהשרת לא זמין. השחזור דורש גישה פיזית לקונסול והליך שחזור סיסמה. המניעה: תמיד לסיים את רשימת השיטות ב-local ולהגדיר משתמש מקומי מראש.

בנק שאלות שתלמידים שואלים – ותשובות מוכנות

שאלות נפוצות בפרק ה-AAA, עם תשובות מוכנות.

מושגי יסוד

ש: "אימות והרשאה נשמעים אותו דבר – מה ההבדל?"

ת: משל שדה התעופה: **אימות** = בדיקת הדרכון (מי אתה). **הרשאה** = כרטיס הטיסה (לאיזה מטוס מותר לך לעלות). קודם מוודאים מי אתה, ורק אז קובעים מה מותר לך. אי אפשר הרשאה בלי אימות.

ש: "ה-key בין הנתב לשרת – זו הסיסמה של המשתמש?"

ת: לא! ה-key הוא סוד משותף בין הנתב לשרת (מצפין ומאמת את הקשר ביניהם). סיסמאות המשתמשים נמצאות בשרת. שני דברים שונים לגמרי.

ש: "MFA ו-2FA זה אותו דבר?"

ת: 2FA (שני גורמים) הוא מקרה פרטי של MFA (רב-גורמי). העיקרון: שילוב גורמים מסינוס סיגוס – משהו שאתה יודע (סיסמה) + משהו שיש לך (טלפון) + משהו שאתה (טביעת אצבע). שתי סיסמאות אינן MFA.

מקומי מול שרת, ותקלות

ש: "אם שרת ה-AAA נופל, ננעלנו החוצה מכל הנתבים?"

ת: לא, אם הגדרתם נכון: רשימת השיטות מסתיימת ב-local (למשל local+ group tacacs+ ...). כשהשרת לא זמין, הנתב עובר אוטומטית לאימות מול משתמש מקומי. לכן דימת משאירים גיבוי מקומי.

ש: "מה קורה אם הקלדתי aaa new-model בטעות בלי משתמש מקומי?"

ת: אתם עלולים להינעל החוצה – כי מרגע הפקודה כל הקווים עוברים ל-AAA, ואם אין משתמש ואין רשימת ברירת מחדל, אין כניסה. כלל ברזל: קודם username, אחר כך aaa new-model, ולהשאיר חלון פתוח עד שבודקים בחלון שני.

ש: "אם השרת עונה 'סיסמה שגויה', הנתב עובר לאימות מקומי?"

ת: לא! מעבר לשיטה הבאה קורה רק כשהשרת נִימז אל (timeout). דחייה מפורשת מהשרת = המשתמש נדחה, בלי מעבר. זו נקודה שנשאלת בבגרות.

RADIUS מול TACACS+

ש: "אז איזה מהם 'יותר טוב', RADIUS או TACACS+?"

ת: תלוי במשימה. לדיוצ לוהין (מנהלים שמתחברים לנתבים, עם אישור לכל פקודה) – TACACS+ עדיף. לתשרל פישמתשמ תשיג (Wi-Fi/802.1X, VPN) – RADIUS. בפועל ארגונים משתמשים בשניהם, כל אחד לתפקידו.

ש: "למה RADIUS על UDP אם TCP אמין יותר?"

ת: RADIUS תוכנן ב-1991 לשרתי דיאל-אפ עם אלפי חיבורים; UDP קל ומהיר, והלקוח פשוט שולח שוב אם אין תשובה. TACACS+ בחר TCP כי הוא מנהל שיחה רב-שלבית ורוצה לדעת מיד אם השרת נפל. שניהם עובדים היום.

ש: "אומרים ש-RADIUS לא עושה הרשאה – אבל הוא כן מחזיר הרשאות, לא?"

ת: נכון, זו נקודה עדינה. RADIUS כן נושא attributes של הרשאה (VLAN, רמה) בתוך תשובת ה-Accept, אבל הוא בלשמ אימות והרשאה בצעד אחד ואינו תומך באישור הדוקף לכל דרפנ כמו TACACS+ בבגרות "אינו מתייחס לניהול הרשאות" מתקבל כנכון במובן הזה.

ש: "מה זה 802.1X במשפט אחד?"

ת: תקן שבו המתג/נקודת הגישה טרופה תא סימסוח עד שהמכשיר מאמת את עצמו מול שרת RADIUS. זה מה שמונע ממישהו לחבר מחשב לשקע ולקבל גישה, וזה הבסיס ל-Wi-Fi ארגוני (WPA2-Enterprise).

ש: "אפשר לחבר AAA ל-Active Directory של בית הספר?"

ת: כן – זה בדיוק מה שעושים בארגונים. שרת ה-AAA (ISE/NPS/FreeRADIUS) מקבל את הבקשה מהנתב ומאמת מול ה-AD/LDAP כך המורים משתמשים באותם שם וסיסמה בכל מקום.

מילון מונחים – הגדרות

הגדרות תמציתיות של המונחים המרכזיים בפרק. שימושי גם כדף עזר לבחינה (מותר מילון מונחים).

מונח	הגדרה
AAA	מסגרת של שלושה שירותים: Authentication, Authorization, Accounting.
Authentication (אימות)	קביעת זהות המשתמש - מי אתה.
Authorization (הרשאה)	קביעת מה מותר למשתמש לעשות אחרי שאומת.
Accounting (רישום)	תיעוד פעולות המשתמש: מתי נכנס, אילו פקודות הקליד.
AAA מקומי	אימות מול מסד משתמשים בקונפיג של הנתב עצמו.
AAA מבוסס-שרת	אימות מול שרת מרכזי (ISE/ACS) בפרוטוקול RADIUS או TACACS+.
NAS / AAA client	ההתקן (נתב/מתג) שפונה לשרת ה-AAA בשם המשתמש.
RADIUS	פרוטוקול AAA פתוח, (1812/1813) UDP; מצפין רק את הסיסמה; לגישת משתמשים.
+TACACS	פרוטוקול AAA של סיסקו, TCP 49; מצפין את כל החבילה; מפריד שירותים; לניהול ציוד.
key / shared secret	סוד משותף בין הנתב לשרת המצפין ומאמת את הקשר ביניהם (לא סיסמת המשתמש).
ACS / ISE	שרתי ה-AAA של סיסקו (ACS) ישן, ISE מודרני).
aaa new-model	הפקודה שמפעילה את מסגרת ה-AAA בנתב.
method list	רשימת שיטות אימות מסודרת; עוברים לשיטה הבאה רק אם הקודמת לא זמינה.
802.1X	תקן שבו המתג/AP חוסם פורט עד לאימות מול שרת RADIUS.
Supplicant / Authenticator	ב-802.1X: המכשיר המבקש גישה (supplicant) והמתג שחוסם (authenticator).
MFA / 2FA	אימות רב-שלבי - שילוב גורמים מסוגים שונים (יודע/יש/הוא).